

Segurança em Sistemas Operacionais e Redes de Computadores II

ISG012-02 - Roteamento Seguro e ACLs - Teoria

Objetivo

- Diferenciar roteamento estático de dinâmico sob a ótica da segurança, configurar um roteador Linux multi-homed utilizando os comandos ip route e ip rule, e implementar ACLs avançadas com nftables filtrando tráfego por interface de entrada e saída, bloqueando comunicação entre VLANs específicas de forma controlada.

Introdução ao Roteamento

- O roteamento é o processo fundamental que determina o caminho que os pacotes de dados percorrem entre redes distintas;
- Em ambientes corporativos, a forma como o tráfego é direcionado impacta diretamente a segurança da infraestrutura;
- Um roteador bem configurado não apenas conecta segmentos, mas também serve como ponto de controle para aplicar políticas de segurança, prevenindo que tráfego não autorizado atravessasse fronteiras de rede;
- A compreensão dos mecanismos de encaminhamento é essencial para arquitetar defesas em camadas, onde o roteamento atua como a primeira barreira lógica contra acessos indevidos.

Introdução ao Roteamento

- **Definição:** Processo de seleção de caminhos em uma rede para encaminhar pacotes entre diferentes segmentos
- **Função do roteador:** Dispositivo de camada 3 que interconecta redes e toma decisões de encaminhamento baseadas em tabelas de roteamento
- **Segurança no roteamento:** O roteador é um ponto crítico de controle onde políticas de acesso podem ser aplicadas
- **Tabela de roteamento:** Estrutura de dados que armazena rotas conhecidas, métricas e interfaces de saída
- **Next-hop:** Endereço IP do próximo dispositivo no caminho até o destino final

Roteamento Estático

- O roteamento estático consiste na configuração manual de rotas na tabela de roteamento pelo administrador da rede;
- Diferente do roteamento dinâmico, não há troca automática de informações entre roteadores;
- Cada entrada é inserida explicitamente, definindo-se a rede de destino, a máscara, o gateway de próximo salto e a interface de saída;
- Do ponto de vista da segurança, o roteamento estático oferece previsibilidade total: o administrador sabe exatamente por onde o tráfego flui, eliminando surpresas causadas por alterações automáticas de topologia;
- No entanto, exige manutenção manual em caso de falhas de links.

Roteamento Estático

- **Configuração manual:** O administrador insere cada rota individualmente no roteador
- **Comando Linux:** `ip route add 192.168.2.0/24 via 192.168.1.1 dev eth0`
- Vantagem de segurança: Previsibilidade total do caminho do tráfego
- **Desvantagem:** Não se adapta automaticamente a falhas de links ou mudanças de topologia
- **Uso recomendado:** Redes pequenas, rotas default, segmentos críticos onde o controle absoluto é necessário
- **Persistência:** Rotas adicionadas via CLI são voláteis; scripts de inicialização garantem persistência

Roteamento Dinâmico — Conceitos de Segurança

- Os protocolos de roteamento dinâmico permitem que roteadores troquem informações de topologia automaticamente, adaptando-se a mudanças na rede;
- RIP (Routing Information Protocol) e OSPF (Open Shortest Path First) são os protocolos interior gateway mais conhecidos;
- Do ponto de vista da segurança, o risco principal reside na possibilidade de um roteador malicioso ou comprometido injetar rotas falsas na rede, desviando tráfego para interceptação (ataque Man-in-the-Middle);
- Por isso, em ambientes seguros, o roteamento dinâmico deve ser combinado com autenticação de vizinhos e filtragem de rotas.

Roteamento Dinâmico — Conceitos de Segurança

- **RIP (Routing Information Protocol):** Protocolo distance-vector com limite de 15 hops; métrica baseada em contagem de saltos
- **RIPv2:** Suporta autenticação por texto ou MD5, VLSM e endereçamento classless
- **OSPF (Open Shortest Path First):** Protocolo link-state que utiliza o algoritmo de Dijkstra; divide a rede em áreas hierárquicas
- **Risco de segurança:** Injeção de rotas falsas por roteadores não autorizados
- **Mitigação:** Autenticação de vizinhos, filtragem de prefixos, uso de áreas OSPF stub

RIP — Fundamentos e Segurança

- RIP é um dos protocolos de roteamento mais antigos, utilizando o algoritmo distance-vector onde cada roteador compartilha sua tabela completa com vizinhos a cada 30 segundos;
- A métrica é simplesmente a contagem de saltos (hops), com um limite máximo de 15, tornando-o inadequado para redes grandes;
- A versão 1 (RIPv1) não possui mecanismos de autenticação, transmitindo atualizações em broadcast, o que a torna insegura;
- A versão 2 (RIPv2) introduziu suporte a autenticação via senha em texto ou hash MD5, além de multicast direcionado (224.0.0.9), reduzindo a exposição de informações de roteamento.

RIP — Fundamentos e Segurança

- **Distance-vector:** Cada roteador conhece apenas a distância (hops) e a direção para cada destino
- **Broadcast vs Multicast:** RIPv1 usa 255.255.255.255; RIPv2 usa 224.0.0.9
- **Autenticação RIPv2:** Suporta senha em texto simples ou MD5 hash
- **Split horizon e poison reverse:** Mecanismos para prevenir loops de roteamento
- **Limite de 15 hops:** Rotas com 16 hops são consideradas inalcançáveis
- **Insegurança inerente:** Ausência de criptografia forte; vulnerável a spoofing de vizinhos

OSPF — Fundamentos e Segurança

- OSPF é um protocolo link-state que constrói um mapa completo da topologia da rede através do banco de dados de estado de links (LSDB);
- Cada roteador calcula independentemente a melhor rota usando o algoritmo SPF (Shortest Path First) de Dijkstra;
- A rede é dividida em áreas hierárquicas, com uma área backbone (Area 0) obrigatória;
- Do ponto de vista da segurança, OSPF suporta autenticação de área (texto simples, MD5 ou SHA) e pode utilizar áreas stub para limitar a propagação de rotas externas;
- A segmentação em áreas reduz o domínio de falhas e limita a exposição da topologia completa.

OSPF — Fundamentos e Segurança

- **Link-state:** Cada roteador possui uma visão completa da topologia da rede
- **Áreas:** Segmentação hierárquica com Area 0 (backbone) como centro
- **ABR (Area Border Router):** Conecta áreas não-backbone ao backbone
- **Autenticação:** Suporta null, simple password e MD5/HMAC-SHA
- **Áreas stub:** Limitam rotas externas (LSAs tipo 5), reduzindo tamanho da LSDB
- **Convergência rápida:** Atualizações triggered (não periódicas) quando há mudanças
- **Métrica de custo:** Baseada na largura de banda do link, não apenas hops

Linux como Roteador Multi-Homed

- Um sistema Linux pode funcionar como roteador quando possui múltiplas interfaces de rede conectadas a segmentos diferentes, configuração conhecida como multi-homed;
- Para que o encaminhamento de pacotes entre interfaces funcione, é necessário habilitar o IP forwarding no kernel (`net.ipv4.ip_forward=1`);
- O comando `ip route` gerencia a tabela de roteamento principal, enquanto `ip rule` implementa Policy-Based Routing (PBR), permitindo que decisões de roteamento considerem não apenas o destino, mas também a origem, a interface de entrada ou marcas de pacotes;
- Essa flexibilidade é crucial para segurança, pois permite isolar tráfego entre segmentos.

Linux como Roteador Multi-Homed

- **Multi-homed:** Sistema com múltiplas NICs em redes distintas
- **IP forwarding:** Habilitado via `sysctl -w net.ipv4.ip_forward=1` ou `/etc/sysctl.conf`
- **ip route:** Gerencia rotas na tabela principal ou em tabelas customizadas
- **ip rule:** Define políticas que selecionam qual tabela de roteamento consultar
- **Tabelas customizadas:** Definidas em `/etc/iproute2/rt_tables` (ex: 200 labnet)
- **Persistência:** Requer scripts em `/etc/network/interfaces` ou NetworkManager dispatcher

Policy-Based Routing (PBR) no Linux

- O Policy-Based Routing estende o roteamento tradicional ao permitir que o administrador defina múltiplas tabelas de roteamento e regras que selecionam qual tabela usar com base em critérios além do endereço de destino;
- O kernel avalia as regras em ordem de prioridade (menor número = maior prioridade). Por padrão, existem três regras: local (prioridade 0), main (32766) e default (32767);
- Com PBR, é possível criar regras como "todo tráfego proveniente da interface eth1 deve usar a tabela 200", ou "pacotes da subnet 192.168.10.0/24 devem sair pelo gateway 10.0.0.1";
- Isso permite segmentar o fluxo de dados de forma granular.

Policy-Based Routing (PBR) no Linux

- **ip rule show:** Lista as regras atuais de roteamento por política
- **Seletores comuns:** from (origem), to (destino), iif (interface entrada), fwmark (marca do firewall)
- **Criação de tabela:** echo "200 labnet" >> /etc/iproute2/rt_tables
- **Adicionar rota à tabela:** ip route add default via 10.0.0.1 dev eth1 table labnet
- **Adicionar regra:** ip rule add from 192.168.10.0/24 table labnet priority 100
- **Verificação:** ip route get 8.8.8.8 from 192.168.10.50 simula a decisão de roteamento

Access Control Lists (ACLs)

- As Listas de Controle de Acesso são regras que permitem ou negam o tráfego de rede baseando-se em critérios como endereços IP de origem/destino, protocolos, portas ou interfaces;
- No contexto de roteamento, as ACLs são aplicadas nas interfaces do roteador para filtrar pacotes que tentam atravessar entre segmentos;
- Diferente de um firewall de host que protege apenas o próprio sistema, ACLs em roteadores controlam o fluxo entre redes inteiras;
- O nftables é o framework moderno no Linux para implementar ACLs, substituindo o antigo iptables com uma sintaxe mais coesa e melhor desempenho.

Access Control Lists (ACLs)

- **Função:** Filtrar tráfego baseado em endereços, protocolos, portas e interfaces
- **Aplicação:** Interfaces de roteador controlam fluxo entre segmentos de rede
- **nftables:** Framework moderno de filtragem de pacotes no Linux
- **Família inet:** Suporta IPv4 e IPv6 simultaneamente na mesma tabela
- **Hooks:** input (para o roteador), forward (através do roteador), output (do roteador)
- **Estado da conexão:** ct state established,related permite tráfego de retorno sem regras explícitas

nftables — Estrutura e Conceitos

- O nftables organiza as regras em uma hierarquia de tabelas, chains e regras;
- Uma tabela é um container que agrupa chains de um mesmo tipo de endereçamento (ip, ip6, inet, arp, bridge, netdev);
- As chains são ancoradas em hooks do kernel — pontos específicos no fluxo de processamento de pacotes como prerouting, input, forward, output e postrouting;
- A chain do tipo filter com hook forward é particularmente importante para roteadores, pois processa pacotes que atravessam o sistema;
- A política padrão (policy drop) define a ação quando nenhuma regra corresponde, sendo a postura de segurança recomendada.

nftables — Estrutura e Conceitos

- **Tabela:** Container para chains; família inet recomendada para dual-stack
- **Chain:** Container para regras; requer type, hook e priority
- **Hook forward:** Processa pacotes que atravessam o roteador entre interfaces
- **Prioridade:** Ordem de processamento; filter tem valor padrão 0
- **Política padrão:** policy drop nega tudo não explicitamente permitido
- **Match iifname/oifname:** Filtra por nome da interface de entrada/saída
- **Persistência:** Configuração salva em /etc/nftables.conf e carregada via systemctl

Filtragem por Interface com nftables

- A capacidade de filtrar pacotes com base na interface de entrada (iifname) e saída (oifname) é fundamental para roteadores multi-homed;
- Essa abordagem permite criar zonas de segurança onde o tráfego entre segmentos é explicitamente controlado;
- Por exemplo, pode-se permitir que a interface eth1 (rede interna) acesse a eth0 (internet), mas bloquear o caminho inverso para novas conexões;
- O uso de variáveis no nftables simplifica a manutenção, permitindo definir nomes simbólicos para interfaces e conjuntos de endereços IP, tornando o ruleset mais legível e menos propenso a erros de configuração.

Filtragem por Interface com nftables

- **iifname:** Match pelo nome da interface de entrada (string comparison)
- **oifname:** Match pelo nome da interface de saída
- **Vantagem sobre iif:** Aceita wildcards (ex: iifname "eth*") e interfaces inexistentes
- **Regra exemplo:** iifname "eth1" oifname "eth0" tcp dport 443 accept
- **Bloqueio entre VLANs:** iifname "eth1.10" oifname "eth1.20" drop
- **Variáveis:** define LAN_DEV = eth1 permite referenciar \$LAN_DEV nas regras
- **Sets:** Coleções de endereços ou interfaces para regras concisas

Bloqueio de Tráfego Entre VLANs

- A segmentação de rede em VLANs é uma prática essencial de segurança, isolando broadcast domains e limitando a propagação de ameaças laterais;
- No entanto, para que diferentes VLANs se comuniquem, é necessário um roteador ou switch Layer 3;
- Esse ponto de interconexão é onde as ACLs devem ser aplicadas para controlar quais fluxos são permitidos;
- Com nftables em um roteador Linux, é possível criar regras específicas que bloqueiam completamente a comunicação entre VLANs sensíveis (ex: VLAN de finanças e VLAN de visitantes), ou permitem apenas protocolos específicos (ex: HTTP da VLAN de visitantes para a VLAN de servidores web, mas nada mais).

Bloqueio de Tráfego Entre VLANs

- **VLAN tagging:** Identificação lógica de segmentos na mesma infraestrutura física
- **Roteamento entre VLANs:** Ocorre no roteador (router-on-a-stick) ou switch Layer 3
- **Ponto de controle:** O roteador é onde as ACLs devem ser aplicadas
- **Regra de isolamento:** `iifname "eth0.10" oifname "eth0.20" drop`
- **Regra seletiva:** `iifname "eth0.20" oifname "eth0.10" tcp dport 80 accept`
- **Logging:** `log prefix "VLAN-BLOCK: "` para auditoria de tentativas de acesso
- **Princípio do menor privilégio:** Negar tudo, permitir apenas o necessário

Path Isolation e Segurança de Roteamento

- O isolamento de caminhos (path isolation) é uma estratégia de segurança que garante que tráfego de diferentes classes de serviço ou níveis de sensibilidade não compartilhem os mesmos caminhos físicos ou lógicos;
- Em ambientes virtualizados, isso pode ser implementado através de redes separadas no hypervisor (como diferentes adaptadores de rede no VirtualBox), cada uma mapeada para uma interface distinta no roteador Linux;
- Combinado com PBR e nftables, o administrador pode garantir que tráfego de gerenciamento nunca transite pela mesma interface que tráfego de visitantes, mesmo que ambos cheguem ao mesmo host físico.

Path Isolation e Segurança de Roteamento

- **Definição:** Garantia de caminhos de rede separados para diferentes tipos de tráfego
- **Implementação:** Interfaces físicas ou virtuais dedicadas por segmento de segurança
- **VirtualBox:** Adaptadores de rede separados para cada segmento (Internal Network 1, 2, 3)
- **PBR para isolamento:** Regras que forçam tráfego de gerenciamento por interface exclusiva
- **nftables para reforço:** Drop de pacotes que tentam "saltar" entre caminhos não autorizados
- **Vantagem:** Comprometimento de um segmento não afeta diretamente os outros
- **Conformidade:** Alinhado com frameworks como ISO 27001 e NIST SP 800-53

Roteamento Estático vs Dinâmico

- A escolha entre roteamento estático e dinâmico envolve trade-offs entre administrabilidade e segurança;
- O roteamento estático oferece controle absoluto e superfície de ataque reduzida (não há protocolos de roteamento escutando em portas UDP), mas não se recupera automaticamente de falhas;
- O roteamento dinâmico oferece resiliência e escalabilidade, mas introduz uma superfície de ataque adicional: protocolos como RIP (UDP 520) e OSPF podem ser explorados se não autenticados;
- Em ambientes de alta segurança, a recomendação é utilizar roteamento estático para segmentos críticos e dinâmico apenas onde a resiliência é mandatória, sempre com autenticação habilitada.

Roteamento Estático vs Dinâmico — Comparativo de Segurança

Critério	Roteamento Estático	Roteamento Dinâmico
Controle	Total (administrador define tudo)	Parcial (protocolo decide)
Resiliência	Manual (requer intervenção)	Automática (convergência)
Superfície de ataque	Mínima (sem portas de protocolo)	Maior (RIP/BGP/OSPF expostos)
Autenticação	N/A (não há troca de informações)	Obrigatória (MD5/SHA em OSPF)
Escalabilidade	Baixa (trabalho manual cresce)	Alta (automatizado)
Previsibilidade	Alta (caminhos fixos)	Baixa (caminhos podem mudar)

Boas Práticas de Roteamento Seguro

- A implementação de roteamento seguro requer uma abordagem em camadas que combine configuração correta do roteador, filtragem de pacotes e monitoramento contínuo;
- Primeiro, desative serviços desnecessários no roteador Linux;
- Segundo, utilize roteamento estático para segmentos críticos onde a previsibilidade é mais importante que a resiliência automática;
- Terceiro, quando usar roteamento dinâmico, habilite autenticação de vizinhos e filtre quais prefixos podem ser anunciados.
- Quarto, aplique ACLs com nftables em todas as interfaces, seguindo o princípio de negação padrão;
- Quinto, mantenha logs de tráfego negado para análise forense. Sexto, documente todas as rotas e regras para auditoria e recuperação de desastres.

Boas Práticas de Roteamento Seguro

- **Desativar serviços:** Remover daemons de roteamento não utilizados
- **Estático para críticos:** Segmentos DMZ, gerenciamento, servidores sensíveis
- **Autenticação dinâmica:** Sempre habilitar em RIPv2, OSPF, EIGRP, BGP
- **Filtragem de prefixos:** Route-maps para limitar quem pode anunciar rotas
- **ACLs default-deny:** policy drop em todas as chains de forward
- **Logging:** Registrar tentativas de acesso negadas para detecção de reconhecimento
- **Documentação:** Diagramas de rede e tabelas de roteamento atualizadas
- **Auditoria:** Revisões periódicas de rotas e regras de firewall

Arquivos da disciplina

- Link para aGoogle Drive com os arquivos da disciplina:
 - https://drive.google.com/drive/folders/1KuGQgeDWI5RLBZntXmgqlx6NkJnvQx_i?usp=sharing
- Link encurtado:
 - <https://ziply.pk/QbJHLB>